

AWS SECURE CLOUD ARCHITECTURE

Defense in Depth — Architecture Documentation

Aisha Okete Zulkifl

Project Type:

Cloud Security Architecture & Implementation

Platform:

Amazon Web Services (AWS) — us-east-1

Architecture Pattern:

3-Tier, Multi-AZ, Defense in Depth

1. Executive Summary

This document describes the design, implementation, and security controls of a production-grade AWS cloud architecture built using a defense-in-depth security model. The architecture was designed from the ground up with security as the primary consideration, following AWS Well-Architected Framework principles and industry best practices for cloud security.

The environment implements a three-tier architecture — public, application, and data — spread across two AWS Availability Zones for fault tolerance and high availability. Every layer of the stack includes independent security controls, ensuring that no single misconfiguration or failure can expose the environment to attack.

This architecture is relevant to cloud security assessments and advisory engagements with enterprise clients, demonstrating practical understanding of layered cloud security controls, least-privilege access, network segmentation, threat detection, and audit logging.

Component	Technology	Purpose
Network	AWS VPC, Subnets, Route Tables	Isolated network environment with segmented tiers
Perimeter	Internet Gateway, NAT Gateway	Controlled inbound and outbound internet access
Load Balancing	Application Load Balancer (ALB)	Public-facing entry point, distributes traffic
Compute	EC2 Auto Scaling Group	Fault-tolerant, scalable application tier
Database	Amazon RDS (MySQL)	Managed database in isolated data tier
Secrets	AWS Secrets Manager	Encrypted credential storage with auto-rotation
Network Security	NACLs + Security Groups	Layered network access controls
Access Management	IAM Roles, SSM Session Manager	Least-privilege access, no SSH required
Threat Detection	Amazon GuardDuty	Continuous 24/7 threat monitoring
Audit Logging	AWS CloudTrail	Complete audit trail of all API activity

2. Architecture Overview

2.1 Design Principles

The architecture was built around five core security principles:

- **Defense in Depth**
 - Multiple independent security layers throughout the stack. A failure or misconfiguration at any single layer does not expose the environment. Network controls, security groups, IAM policies, and monitoring all operate independently.
- **Least Privilege Access**
 - Every AWS resource, IAM role, security group, and NACL rule is scoped to the minimum permissions required to function. No resource has broader access than it needs.
- **Network Segmentation**
 - The environment is divided into three distinct network tiers — public, application, and data — each with its own security boundary. Traffic can only flow between tiers in defined, controlled ways.
- **Zero Standing Privileges**
 - No SSH keys are used anywhere in the environment. All instance access is performed through AWS Systems Manager Session Manager, which requires no open inbound ports and provides a full audit trail.
- **Visibility and Auditability**
 - All API activity is logged via CloudTrail. All network threats are monitored via GuardDuty. Session activity is logged via SSM. The environment provides complete visibility into who did what, when, and from where.

2.2 Three-Tier Architecture

The environment implements a classic three-tier architecture, where each tier is isolated from the others using network-level controls:

Tier	Subnet	CIDR	AZ	Purpose
Public	public-subnet-1	10.0.1.0/24	us-east-1a	Load Balancer — internet-facing
Public	public-subnet-2	10.0.2.0/24	us-east-1b	Load Balancer — internet-facing
Application	app-private-subnet-1	10.0.3.0/24	us-east-1a	EC2 instances — private
Application	app-private-subnet-2	10.0.4.0/24	us-east-1b	EC2 instances — private
Data	data-private-subnet-1	10.0.5.0/24	us-east-1a	RDS database — isolated

Tier	Subnet	CIDR	AZ	Purpose
Data	data-private-subnet-2	10.0.6.0/24	us-east-1b	RDS database — isolated

2.3 Traffic Flow

All inbound traffic follows a strictly defined path through the architecture:

- Internet traffic arrives at the Internet Gateway (IGW) attached to the VPC
- The IGW performs NAT translation and forwards traffic to the ALB in the public subnet
- The ALB terminates the connection, performs health checks, and forwards to a healthy EC2 instance in the application tier
- EC2 instances process the request and communicate with the RDS database in the data tier over the internal VPC network
- Responses travel back through the same path in reverse

Outbound traffic from private instances follows a separate path:

- Application instances route outbound traffic to the NAT Gateway in the public subnet
- The NAT Gateway forwards traffic through the IGW to the internet
- This allows instances to reach AWS services (SSM, package repositories) without being reachable from the internet

3. Network Security

3.1 VPC Configuration

A dedicated VPC (secure-vpc) with CIDR 10.0.0.0/16 was created to provide complete network isolation from other AWS accounts and the default VPC. Using a dedicated VPC ensures no accidental resource sharing and gives full control over all network settings.

The VPC is configured with DNS resolution and DNS hostnames enabled, which is required for SSM Session Manager and other AWS services to function correctly within the private network.

3.2 Internet Gateway and NAT Gateway

Resource	Placement	Purpose	Security Implication
Internet Gateway	VPC level	Bidirectional internet access for public subnets	Only resources in public subnets with a route to IGW are internet-reachable

Resource	Placement	Purpose	Security Implication
NAT Gateway	public-subnet-1	Outbound-only internet access for private subnets	Private instances can call out but cannot be reached from internet

The NAT Gateway intentionally sits in the public subnet and has an Elastic IP assigned. Private instances route outbound traffic through it for software updates, SSM agent communication, and other legitimate outbound calls. Because NAT is stateful and only tracks connections initiated from inside, no inbound connection from the internet can be established through it.

3.3 Route Tables

Each tier has a dedicated route table, explicitly defining where traffic can travel. This prevents accidental internet exposure of private resources.

Route Table	Associated Subnets	Routes	Effect
public-rt	public-subnet-1, public-subnet-2	10.0.0.0/16 → local 0.0.0.0/0 → IGW	Full internet access for ALB
app-private-rt	app-private-subnet-1, app-private-subnet-2	10.0.0.0/16 → local 0.0.0.0/0 → NAT Gateway	Outbound-only internet for EC2 instances
data-rt	data-private-subnet-1, data-private-subnet-2	10.0.0.0/16 → local	No internet access whatsoever for RDS

3.4 Network Access Control Lists (NACLs)

NACLs provide subnet-level stateless packet filtering. Because NACLs are stateless, both inbound and outbound rules must explicitly permit traffic in both directions. This makes them more complex than security groups but provides an independent layer of control that cannot be bypassed even by misconfigured security groups.

Public NACL (public-nacl)

Direction	Rule	Port/Range	Source/Destination	Action	Rationale
Inbound	100	80 (HTTP)	0.0.0.0/0	Allow	Accept user web traffic to ALB
Inbound	300	1024-65535	0.0.0.0/0	Allow	Allow ephemeral port responses from internet

Direction	Rule	Port/Range	Source/Destination	Action	Rationale
Inbound	*	All	0.0.0.0/0	Deny	Implicit deny — all other inbound traffic blocked
Outbound	100	80 (HTTP)	10.0.3.0/24	Allow	ALB forwards requests to app subnet AZ-a
Outbound	110	80 (HTTP)	10.0.4.0/24	Allow	ALB forwards requests to app subnet AZ-b
Outbound	200	1024-65535	0.0.0.0/0	Allow	ALB sends responses back to users on ephemeral ports
Outbound	*	All	0.0.0.0/0	Deny	Implicit deny — all other outbound traffic blocked

Application NACL (app-nacl)

Direction	Rule	Port/Range	Source/Destination	Action	Rationale
Inbound	100	80 (HTTP)	10.0.1.0/24	Allow	Accept requests from ALB in public subnet AZ-a
Inbound	110	80 (HTTP)	10.0.2.0/24	Allow	Accept requests from ALB in public subnet AZ-b
Inbound	200	1024-65535	0.0.0.0/0	Allow	Allow responses to outbound calls (SSM, updates)
Inbound	*	All	0.0.0.0/0	Deny	Implicit deny
Outbound	100	1024-65535	10.0.1.0/24	Allow	Instance responses back to ALB in AZ-a
Outbound	110	1024-65535	10.0.2.0/24	Allow	Instance responses back to ALB in AZ-b
Outbound	200	443 (HTTPS)	0.0.0.0/0	Allow	Instances call SSM service and fetch updates

Direction	Rule	Port/Range	Source/Destination	Action	Rationale
Outbound	300	1024-65535	0.0.0.0/0	Allow	Ephemeral ports for outbound calls
Outbound	*	All	0.0.0.0/0	Deny	Implicit deny

Data NACL (data-nacl)

Direction	Rule	Port/Range	Source/Destination	Action	Rationale
Inbound	100	3306 (MySQL)	10.0.3.0/24	Allow	Accept DB connections from app tier AZ-a
Inbound	110	3306 (MySQL)	10.0.4.0/24	Allow	Accept DB connections from app tier AZ-b
Inbound	*	All	0.0.0.0/0	Deny	Implicit deny — no other source allowed
Outbound	100	1024-65535	10.0.3.0/24	Allow	DB responses to app tier AZ-a on ephemeral ports
Outbound	110	1024-65535	10.0.4.0/24	Allow	DB responses to app tier AZ-b on ephemeral ports
Outbound	*	All	0.0.0.0/0	Deny	Implicit deny — no internet access whatsoever

3.5 Security Groups

Security groups provide stateful instance-level firewalling. Unlike NACLs, security groups automatically track connection state, so responses to allowed inbound connections are automatically permitted without needing an explicit outbound rule. Security groups reference each other by ID rather than IP address, ensuring rules remain valid even as resources scale and IP addresses change.

ALB Security Group (alb-sg)

Direction	Port	Source/Destination	Action	Rationale
Inbound	80 (HTTP)	0.0.0.0/0	Allow	Accept web traffic from the internet
Outbound	80 (HTTP)	app-sg	Allow	Forward requests to app instances only

Application Security Group (app-sg)

Direction	Port	Source/Destination	Action	Rationale
Inbound	80 (HTTP)	alb-sg	Allow	Only the ALB can reach instances — not the internet
Outbound	443 (HTTPS)	0.0.0.0/0	Allow	Instances call SSM service and download updates
Outbound	3306 (MySQL)	data-sg	Allow	Instances communicate with database only

Data Security Group (data-sg)

Direction	Port	Source/Destination	Action	Rationale
Inbound	3306 (MySQL)	app-sg	Allow	Only app instances can connect to the database
Outbound	All	0.0.0.0/0	Allow	Default outbound — harmless as data-rt has no internet route

The data tier relies on three independent controls to block unauthorized database access: the data-rt route table (no internet route), the data-nacl (only allows traffic from app subnets), and data-sg (only allows traffic from app-sg). All three must be bypassed simultaneously for unauthorized access — a practical impossibility.

4. Compute — Auto Scaling Group

4.1 Launch Template

A Launch Template (app-launch-template) defines the configuration for all EC2 instances launched by the Auto Scaling Group. Using a Launch Template ensures consistency — every instance that launches has identical security configuration, eliminating configuration drift.

Setting	Value	Security Rationale
AMI	Amazon Linux 2023	AWS-maintained, regularly patched OS
Instance Type	t2.micro	Minimum viable compute for this workload
Key Pair	None	No SSH keys — SSM Session Manager is used instead
Public IP	Disabled	Instances have no public IP — not reachable from internet
Security Group	app-sg	Least-privilege security group — only ALB can reach instances
IAM Profile	instanceRole	Provides SSM and CloudWatch access only — no other permissions
Subnet	Defined in ASG	Private subnets only — app-private-subnet-1 and app-private-subnet-2

4.2 Auto Scaling Group

The Auto Scaling Group (app-asg) manages the lifecycle of EC2 instances, automatically maintaining the desired number of healthy instances across both Availability Zones. This provides both fault tolerance and the ability to scale capacity in response to demand.

Setting	Value	Rationale
Desired Capacity	2	Two instances across two AZs for high availability
Minimum Capacity	2	Always maintain at least 2 for fault tolerance
Maximum Capacity	4	Allow scaling up to 4 under high load
Scaling Policy	Target Tracking — 50% CPU	Automatically scales when CPU exceeds 50%
Health Check Type	ELB	Use ALB health checks to detect unhealthy instances
Subnets	app-private-subnet-1, app-private-subnet-2	Spread across two AZs
Target Group	app-tg	Automatically registers new instances with the ALB

When an instance becomes unhealthy (as detected by the ALB health check), the ASG automatically terminates it and launches a replacement. New instances are registered with the target group automatically and begin receiving traffic only after passing health checks.

5. Data Tier — RDS and Secrets Manager

5.1 Amazon RDS

A MySQL 8.4 database instance (secure-db) runs in the data tier, which is the most isolated network tier in the architecture. The database is accessible only from the application tier and has no internet connectivity whatsoever — not even outbound.

Setting	Value	Security Rationale
Engine	MySQL 8.4 (Community)	Open standard, widely supported
Instance Type	db.t4g.micro	Minimum viable for this workload
Multi-AZ	No (Single-AZ)	Single-AZ for this project; Multi-AZ recommended for production
Public Access	No	No public IP — not reachable from internet under any circumstances
Subnet Group	data-subnet-group	Confined to data-private-subnet-1 and data-private-subnet-2
Security Group	data-sg	Only app-sg can connect on port 3306
Storage Encryption	Enabled (default)	Data encrypted at rest using AWS-managed KMS key
Automated Backups	Enabled	Daily backups with 7-day retention for disaster recovery
Credentials	AWS Secrets Manager	Password never hardcoded — managed and rotated by AWS

5.2 AWS Secrets Manager

Database credentials are managed entirely by AWS Secrets Manager. When the RDS instance was created, the option to manage credentials in Secrets Manager was selected. This means:

- AWS generated a strong random password automatically
- The password is stored encrypted in Secrets Manager using AWS KMS
- The password is automatically rotated on a schedule — no manual rotation required

- Application code retrieves the password at runtime by calling the Secrets Manager API — the password never appears in source code, configuration files, or environment variables
- Even if source code is exposed, no credentials are revealed

This approach eliminates an entire class of security vulnerability — hardcoded or improperly stored database credentials — which is one of the most common causes of data breaches in cloud environments.

6. Identity and Access Management

6.1 IAM Role — `instanceRole`

All EC2 instances in the application tier are assigned the `instanceRole` IAM role. This role is scoped to the minimum permissions required for the instances to function — a direct application of the least-privilege principle.

Policy	Type	Permissions Granted	Why Needed
AmazonSSMManagedInstanceCore	AWS Managed	Register with SSM, receive session commands, send session output	Required for SSM Session Manager — replaces SSH
CloudWatchAgentServerPolicy	AWS Managed	Send metrics and logs to CloudWatch	Required for application and system monitoring

The role explicitly grants no access to S3, IAM, RDS, EC2 control plane, or any other AWS service. This was verified using the IAM Policy Simulator, which confirmed that all actions outside of SSM and CloudWatch are implicitly denied.

6.2 SSM Session Manager

All administrative access to EC2 instances is performed through AWS Systems Manager Session Manager. This approach provides significant security advantages over traditional SSH:

Aspect	Traditional SSH	SSM Session Manager
Port 22	Must be open inbound	Not required — no inbound ports
Key Management	SSH keys must be distributed and managed	No keys — IAM authentication only

Aspect	Traditional SSH	SSM Session Manager
Attack Surface	Port 22 exposed to internet scanning and brute force	No exposed port — invisible to internet
Audit Trail	Limited — requires additional logging setup	Every session logged in CloudTrail automatically
Access Control	Key possession grants access	IAM policy controls who can start sessions
Bastion Host	Often required for private instances	Not required — SSM agent reaches out through NAT

The SSM agent runs on each instance and maintains a persistent outbound connection to the AWS SSM service. When an administrator initiates a session, AWS pushes it down this existing connection — no new inbound connection is ever opened. This means even a completely misconfigured security group cannot expose an SSH port, because there is no SSH port to expose.

7. Threat Detection and Audit Logging

7.1 AWS CloudTrail

AWS CloudTrail is enabled across all regions with a trail (secure-trail) that captures all management events. Every API call made to any AWS service in this account is recorded, including who made the call, when, from which IP address, and what the result was.

Setting	Value	Rationale
Trail Name	secure-trail	Single trail covering all regions
Multi-Region	Yes	Captures activity in all AWS regions, not just us-east-1
Event Types	Management events (Read + Write)	Records all resource creation, modification, and deletion
Storage	S3 bucket (auto-created)	Logs stored durably in S3 for long-term retention
Log Validation	Enabled	Cryptographic validation ensures logs have not been tampered with
CloudWatch Logs	Enabled	Logs streamed to CloudWatch for real-time alerting and search
Encryption	S3 default encryption	Logs encrypted at rest

CloudTrail answers the critical forensic questions that arise during a security incident: who made this change, when did it happen, from which IP address, and was the action successful? Without CloudTrail, these questions cannot be answered after the fact.

7.2 Amazon GuardDuty

Amazon GuardDuty is enabled on the account and continuously monitors for threats using machine learning, anomaly detection, and integrated threat intelligence. GuardDuty operates entirely at the control plane level — it does not require agents, does not affect performance, and does not require any additional configuration to begin detecting threats.

GuardDuty monitors the following data sources automatically:

- AWS CloudTrail event logs — detects unusual API activity
- VPC Flow Logs — detects unusual network traffic patterns
- DNS logs — detects communication with known malicious domains
- EC2 instance findings — detects cryptocurrency mining, port scanning, and data exfiltration

Example threats GuardDuty would detect in this environment:

Threat	GuardDuty Finding	Trigger
Compromised EC2 instance	UnauthorizedAccess:EC2/MaliciousIPCaller	Instance communicates with known malicious IP
Credential theft attempt	CredentialAccess:IAMUser/AnomalousBehavior	Unusual IAM API calls from instance
Crypto mining	CryptoCurrency:EC2/BitcoinTool.B!DNS	Instance makes DNS queries to mining pools
Port scanning	Recon:EC2/PortProbeUnprotectedPort	Instance receives unusual port scan traffic
Data exfiltration	Exfiltration:S3/AnomalousBehavior	Unusual data transfer patterns detected

8. High Availability and Fault Tolerance

8.1 Multi-AZ Design

Every tier of the architecture spans two AWS Availability Zones (us-east-1a and us-east-1b). An Availability Zone is a physically separate data centre with independent power, cooling, and networking. By distributing resources across two AZs, the architecture remains available even if one AZ experiences a complete outage.

Component	AZ-a (us-east-1a)	AZ-b (us-east-1b)	Failover Behavior
ALB	ALB node in public-subnet-1	ALB node in public-subnet-2	Automatically routes around failed AZ
EC2 Instances	Instance in app-private-subnet-1	Instance in app-private-subnet-2	ASG maintains desired count across AZs
RDS	Primary in data-private-subnet-1	Standby available if upgraded to Multi-AZ	Manual failover (Single-AZ for this project)

8.2 Auto Scaling Behavior

The Auto Scaling Group ensures the desired number of instances is always running. The target tracking policy (50% CPU utilization) means the ASG will:

- Scale out (add instances) when average CPU exceeds 50% — handles traffic spikes automatically
- Scale in (remove instances) when average CPU drops below 50% — reduces cost during low traffic
- Replace unhealthy instances automatically — if an instance fails its ALB health check, ASG terminates and replaces it
- Maintain minimum capacity of 2 — ensures high availability even during scale-in events

9. Security Control Mapping

The following table maps each security control implemented in this architecture to relevant security frameworks and standards. This mapping is relevant for cloud security assessments and demonstrates alignment with industry best practices.

Control	Implementation	CIS AWS Benchmark	AWS Well-Architected	NIST CSF
Network segmentation	3-tier VPC with public, app, and data subnets	CIS 5.x	SEC 6	PR.AC-5
Least privilege access	IAM roles scoped to SSM + CloudWatch only	CIS 1.x	SEC 2	PR.AC-4
No SSH exposure	SSM Session Manager — no port 22 anywhere	CIS 5.2	SEC 6	PR.AC-3
Subnet-level filtering	NACLs on all three tiers	CIS 5.x	SEC 6	PR.AC-5
Instance-level filtering	Security groups with SG-to-SG references	CIS 5.x	SEC 6	PR.AC-5

Control	Implementation	CIS AWS Benchmark	AWS Well-Architected	NIST CSF
Encrypted credentials	Secrets Manager with auto-rotation	CIS 1.x	SEC 3	PR.DS-1
Audit logging	CloudTrail multi-region with log validation	CIS 3.x	SEC 4	DE.AE-3
Threat detection	GuardDuty continuous monitoring	CIS 3.x	SEC 4	DE.CM-1
Encryption at rest	RDS storage encryption enabled	CIS 2.x	SEC 8	PR.DS-1
High availability	Multi-AZ across us-east-1a and us-east-1b	—	REL 6	PR.IP-8
Auto scaling	ASG with ELB health checks and target tracking	—	REL 7	PR.IP-8
Private instances	No public IP on EC2 instances	CIS 5.x	SEC 6	PR.AC-5
NAT Gateway	Outbound-only internet for private subnets	CIS 5.x	SEC 6	PR.AC-5
Log integrity	CloudTrail log file validation enabled	CIS 3.x	SEC 4	PR.DS-6

10. Known Limitations and Recommendations

The following items were not implemented in this project, either due to cost constraints or scope, and are recommended for a production deployment:

Item	Current State	Recommendation	Reason
HTTPS / TLS	HTTP only (port 80)	Add ACM certificate and HTTPS listener on ALB	Encrypts traffic between users and the ALB
RDS Multi-AZ	Single-AZ deployment	Enable Multi-AZ for production RDS	Automatic failover if primary AZ fails
VPC Flow Logs	Not enabled	Enable VPC Flow Logs to S3 or CloudWatch	Network-level visibility and forensic capability
WAF	Not configured	Add AWS WAF to ALB for Layer 7 protection	Protects against SQL injection, XSS, and other web attacks
VPC Endpoints	Using NAT Gateway for AWS services	Add VPC Endpoints for SSM, S3, CloudWatch	Keeps AWS service traffic inside AWS network — more secure and cheaper than NAT

Item	Current State	Recommendation	Reason
GuardDuty Alerting	Detection only	Configure SNS alerts for high-severity findings	Ensures findings trigger immediate response
Config Rules	Not configured	Enable AWS Config with compliance rules	Continuous compliance monitoring and drift detection
Backup Strategy	RDS automated backups only	Implement AWS Backup for all resources	Centralized backup management and cross-region copies

11. Appendix — Resource Inventory

Resource	Name/ID	Type	Region/AZ
VPC	secure-vpc	10.0.0.0/16	us-east-1
Internet Gateway	secure-igw	IGW	us-east-1
NAT Gateway	secure-nat	Public NAT	us-east-1a
Subnet	public-subnet-1	Public — 10.0.1.0/24	us-east-1a
Subnet	public-subnet-2	Public — 10.0.2.0/24	us-east-1b
Subnet	app-private-subnet-1	Private — 10.0.3.0/24	us-east-1a
Subnet	app-private-subnet-2	Private — 10.0.4.0/24	us-east-1b
Subnet	data-private-subnet-1	Private — 10.0.5.0/24	us-east-1a
Subnet	data-private-subnet-2	Private — 10.0.6.0/24	us-east-1b
Route Table	public-rt	IGW route	us-east-1
Route Table	app-private-rt	NAT route	us-east-1
Route Table	data-rt	Local only	us-east-1
NACL	public-nacl	Public subnet controls	us-east-1
NACL	app-nacl	App subnet controls	us-east-1
NACL	data-nacl	Data subnet controls	us-east-1
Security Group	alb-sg	ALB firewall	us-east-1
Security Group	app-sg	Instance firewall	us-east-1
Security Group	data-sg	Database firewall	us-east-1
Load Balancer	app-alb	Application Load Balancer	us-east-1 (multi-AZ)
Target Group	app-tg	HTTP:80 health checks	us-east-1

Resource	Name/ID	Type	Region/AZ
Launch Template	app-launch-template	Amazon Linux 2023, t2.micro	us-east-1
Auto Scaling Group	app-asg	Min:2 Max:4 Desired:2	us-east-1 (multi-AZ)
RDS Instance	secure-db	MySQL 8.4, db.t4g.micro	us-east-1a
Secrets Manager	rds!secure-db-admin	Database credentials	us-east-1
IAM Role	instanceRole	SSM + CloudWatch only	Global
CloudTrail	secure-trail	Multi-region management events	All regions
GuardDuty	Enabled	Continuous threat detection	us-east-1